

Ola 2 Seguridad

Operacion controlada, adjuntos y backup del piloto

Fecha base: 2026-05-07

Fuente: 14-ola-2-seguridad-operacion-controlada.md

Documento generado para ejecutar el piloto de P&Pmis Ai SaaS como plataforma colaborativa en línea de Project Controls, con trazabilidad por roles, workflows, Cost Manager, AWP, contratos, claims y readiness.

Contenido

- Objetivo
- Alcance Cerrado En Esta Iteracion
- Lo Que Queda Para Cerrar Ola 2 Completa
- Gate De Seguridad
- Backup Controlado
- Politica Operativa Para Adjuntos
- Politica Operativa Para Confidencialidad
- Checklist De Cierre Parcial
- Criterio De No Romper
- Decision

Fecha base: 2026-05-07

Objetivo

Robustecer el piloto sin cambiar su flujo funcional. Esta ola mueve la plataforma de "piloto operativo local" hacia "beta controlada", reforzando accesos, adjuntos, backup y evidencia operativa.

Alcance Cerrado En Esta Iteracion

- Gate de seguridad tools/pilot_security_gate.ps1.
- Prueba automatizada para impedir que usuarios sin membresia listen o descarguen adjuntos.
- Validacion de descarga anonima: debe responder 401.
- Script de backup controlado tools/pilot_backup.ps1 para PostgreSQL y volumen documental.
- Verificador no destructivo tools/pilot_backup_verify.ps1 para validar dump y ZIP sin restaurar sobre datos vivos.
- Ensayo de restore aislado tools/pilot_restore_rehearsal.ps1 en un contenedor temporal de PostgreSQL.
- Endpoint de auditoria consultable GET /api/v1/projects/{project_id}/audit-logs.
- Prueba automatizada para auditoria con alcance por membresia.
- Preparacion OIDC configurable mediante GET /api/v1/auth/providers y variables OIDC_*.
- Escaneo configurable de adjuntos con DOCUMENT_SCAN_MODE=local|clamav|disabled; modo local bloquea EICAR y modo clamav usa INSTREAM.
- Permisos documentales por confidencialidad: restricted/private/executive queda limitado a Control Manager o Document Controller.
- Documentacion operativa de seguridad y backup.

Lo Que Queda Para Cerrar Ola 2 Completa

- Flujo browser OIDC completo con callback, intercambio de código y validación JWKS.
- MFA según política del cliente.
- API tokens para integraciones.
- Servicio ClamAV productivo y política de cuarentena.
- Vista avanzada de auditoría con filtros y export.
- Restore ensayado contra ambiente staging persistente, no solo contenedor temporal.
- Retención formal de documentos.
- Permisos finos por carpeta, paquete documental y organización externa.

Gate De Seguridad

Ejecutar:

```
powershell -ExecutionPolicy Bypass -File .\tools\pilot_security_gate.ps1
```

El gate valida:

- API, frontend, readiness y dashboard mediante pilot_robust_gate.ps1.
- CTRL-DEMO-001 sigue en ready.
- Usuario secundario sin membresia no puede listar adjuntos de REF-TURN-002.
- Usuario secundario sin membresia no puede listar auditoria de REF-TURN-002.
- Endpoint de auditoria de CTRL-DEMO-001 devuelve eventos.
- Descarga autenticada de adjuntos responde 200.
- Descarga anonima de adjuntos responde 401.
- Adjuntos con scan infected no pasan el gate.
- Endpoint de proveedores de auth reporta local y preparacion OIDC.

Backup Controlado

Ejecutar:

```
powershell -ExecutionPolicy Bypass -File .\tools\pilot_backup.ps1
```

Salida esperada:

- Dump PostgreSQL en formato custom.
- ZIP del volumen /app/storage/documents.
- manifest.json con fecha, nombres de archivo y nota de restauracion.

Validacion no destructiva:

```
powershell -ExecutionPolicy Bypass -File .\tools\pilot_backup_verify.ps1
```

El verificador:

- Lee manifest.json.
- Valida que el dump existe y no esta vacio.
- Ejecuta pg_restore -l dentro del contenedor DB para comprobar que el dump es legible.
- Abre el ZIP documental y valida que no tenga entradas con rutas inseguras.
- No restaura ni pisa datos existentes.

Ensayo de restore aislado:

```
powershell -ExecutionPolicy Bypass -File .\tools\pilot_restore_rehearsal.ps1
```

Este ensayo:

- Crea un contenedor temporal postgres:16-alpine.
- Restaura el dump en una base temporal pypmis_restore.
- Verifica que existan tablas publicas restauradas.
- Elimina el contenedor temporal al finalizar.
- No toca la base viva del piloto.

La ruta por defecto es:

```
.\backups\pilot\<timestamp>
```

Politica Operativa Para Adjuntos

Durante el piloto:

- Solo usuarios con membresia de proyecto pueden listar o descargar adjuntos.
- Usuarios anonimos no pueden descargar archivos.
- Ejecutables y scripts siguen bloqueados.
- ZIP con rutas inseguras o ZIP anidados siguen bloqueados.
- Todo archivo debe tener sha256, tamano, extension y origen.
- pending_scan se acepta solo como estado temporal hasta integrar antivirus real.
- Para pilotos con informacion sensible, usar DOCUMENT_SCAN_MODE=clamav y levantar un servicio ClamAV reachable por la API.

Politica Operativa Para Confidencialidad

- project, team, internal o vacio: cualquier miembro del proyecto puede listar y descargar.
- confidential o controlled: Control Manager, Project Controls, Document Controller o Contract Manager.
- restricted, private o executive: Control Manager o Document Controller.
- Los listados de adjuntos filtran archivos no autorizados y las rutas directas de descarga devuelven 403.

Checklist De Cierre Parcial

```
docker compose build api
docker compose up -d api
docker compose exec -T api pytest
docker compose exec -T frontend npm run build
powershell -ExecutionPolicy Bypass -File .\tools\pilot_security_gate.ps1
powershell -ExecutionPolicy Bypass -File .\tools\pilot_backup.ps1
powershell -ExecutionPolicy Bypass -File .\tools\pilot_backup_verify.ps1
powershell -ExecutionPolicy Bypass -File .\tools\pilot_restore_rehearsal.ps1
powershell -ExecutionPolicy Bypass -File .\tools\pilot_check.ps1
```

Criterio De No Romper

La Ola 2 parcial queda aceptada solo si:

- pytest pasa.
- Frontend compila.
- pilot_security_gate.ps1 pasa.
- CTRL-DEMO-001 queda ready 100.0%.
- API, frontend, DB, Redis y worker siguen arriba.

Decision

Con este subpaquete, el piloto queda mejor protegido para operar con usuarios limitados. La base de OIDC, permisos por confidencialidad, escaneo local/ClamAV configurable y restore aislado ya esta preparada. Aun no debe recibir informacion sensible de produccion hasta activar un proveedor OIDC real, operar ClamAV productivo con cuarentena, ensayar restore en staging persistente y definir permisos por carpeta/organizacion externa.